



TRƯỜNG ĐẠI HỌC CÔNG THƯƠNG TP.HCM
KHOA CÔNG NGHỆ THÔNG TIN

ĐỀ CƯƠNG CHI TIẾT
ĐỒ ÁN CHUYÊN NGÀNH ATTT NĂM HỌC 2026 - 2027

1. Mã đề tài:

2. Tên đề tài: Xây dựng mô hình kiểm thử lỗ hổng SMB trên Windows bằng Kali Linux

3. Định hướng đề tài: An toàn hệ thống và kiểm thử xâm nhập

☒ Định hướng Ứng dụng

4. Thông tin GVHD

- Họ tên giảng viên: Ngô Quốc Huy
- Điện thoại: 0936161436
- Email: huynq@huit.edu.vn

5. Nhóm sinh viên thực hiện đề tài

- | | | |
|------------------------------|------------------|---------------|
| 1) Họ tên: Lâm Gia Bảo | MSSV: 2033216350 | Lớp: 12DHBM03 |
| 2) Họ tên: Nguyễn Minh Thắng | MSSV: 2033216558 | Lớp: 12DHBM03 |
| 3) Họ tên: Nguyễn Hoài Tiến | MSSV: 2033216575 | Lớp: 12DHBM09 |

6. Mục tiêu:

- Trình bày được vai trò, kiến trúc và cơ chế hoạt động của dịch vụ Server Message Block (SMB) trên Windows; phân biệt SMBv1, SMBv2 và SMBv3.
- Giải thích được quá trình thương lượng phiên bản, xác thực, thiết lập phiên và truy cập tài nguyên chia sẻ qua TCP 139/445.
- Phân tích được phạm vi của bản tin MS17-010, các phiên bản Windows bị ảnh hưởng và mối liên hệ với EternalBlue/CVE-2017-0144.
- Xác định đúng điều kiện cần để đánh giá MS17-010; không đồng nhất việc cổng 445 mở, SMBv1 được bật và hệ thống thực sự chưa được vá.
- Mô tả được vai trò của Kali Linux, Nmap, Nmap Scripting Engine và Metasploit Framework trong quy trình kiểm thử bảo mật.
- Thiết kế được mô hình lab cô lập gồm máy Kali Linux và máy Windows mục tiêu, có sơ đồ mạng, bảng địa chỉ IP và cơ chế snapshot phục hồi.
- Thực hiện được bước phát hiện máy chủ, quét cổng, nhận diện dịch vụ và xác định phiên bản SMB bằng Nmap trong phạm vi được cấp phép.
- Xây dựng được tiêu chí xác minh MS17-010 và thực nghiệm kiểm thử có kiểm soát, có điều kiện bắt đầu, điều kiện dừng và phương án khôi phục.
- Thu thập được log, kết quả lệnh, ảnh minh chứng và bảng đối chiếu để chứng minh từng kết luận kỹ thuật.



TRƯỜNG ĐẠI HỌC CÔNG THƯƠNG TP.HCM

KHOA CÔNG NGHỆ THÔNG TIN

- Đánh giá được rủi ro đối với tính bí mật, toàn vẹn và sẵn sàng của hệ thống khi SMB được cấu hình không an toàn hoặc chưa được vá.
- Triển khai được các biện pháp giảm thiểu gồm cập nhật bản vá, vô hiệu hóa SMBv1, giới hạn TCP 445 và phân đoạn mạng.
- Kiểm thử lại bằng cùng bộ tiêu chí để so sánh trạng thái trước và sau khi áp dụng biện pháp phòng thủ.
- Nhận diện được rủi ro còn lại và ảnh hưởng tương thích có thể phát sinh khi thay đổi cấu hình SMB.
- Lập kế hoạch, phân công và theo dõi tiến độ công việc của nhóm trong thời gian 10 tuần.
- Hoàn thiện báo cáo đúng biểu mẫu, sử dụng thuật ngữ kỹ thuật chính xác và trích dẫn nguồn có thẩm quyền.
- Trình bày, bảo vệ được phương pháp, kết quả, giới hạn của thực nghiệm và trả lời phản biện của giảng viên.

7. Yêu cầu

- Các nội dung cụ thể cần thực hiện:
 - + Tìm hiểu nền tảng SMB trên Windows: thành phần client/server, dialect, phiên làm việc, xác thực, chia sẻ tài nguyên và các cổng liên quan.
 - + Tìm hiểu MS17-010 như một nhóm lỗ hổng SMBv1; lập bảng đối chiếu CVE, hệ điều hành bị ảnh hưởng, điều kiện khai thác, tác động và bản vá tương ứng.
 - + Nghiên cứu Nmap và các NSE script phục vụ phát hiện SMB; giải thích ý nghĩa của trạng thái cổng và giới hạn của kết quả nhận diện tự động.
 - + Nghiên cứu kiến trúc Metasploit Framework, phân biệt module auxiliary, exploit và payload; chỉ sử dụng module phù hợp với mục tiêu đã được phê duyệt.
 - + Xây dựng lab cô lập, ghi rõ cấu hình phần cứng ảo, phiên bản hệ điều hành, bản dựng Windows, trạng thái bản vá, phiên bản công cụ và bảng địa chỉ IP.
 - + Tạo snapshot trước thực nghiệm; không dùng Bridged Adapter và không quét hoặc khai thác bất kỳ hệ thống nào ngoài phạm vi lab.
 - + Thực nghiệm phát hiện máy Windows, quét TCP 139/445, nhận diện dịch vụ và phiên bản SMB; lưu kết quả gốc để đối chứng.
 - + Thực nghiệm xác minh MS17-010 theo tiêu chí đã xác định; kết luận phải phân biệt rõ: có dịch vụ SMB, có SMBv1, nghi ngờ lỗ hổng và đã xác minh lỗ hổng.
 - + Thực hiện kịch bản kiểm thử có kiểm soát sau khi giải thích được cơ chế lỗ hổng, điều kiện tác động và phương án phục hồi; dừng ngay khi xuất hiện ảnh hưởng ngoài dự kiến.



TRƯỜNG ĐẠI HỌC CÔNG THƯƠNG TP.HCM
KHOA CÔNG NGHỆ THÔNG TIN

- + Phân tích kết quả theo khả năng xảy ra và mức độ tác động; lập bảng rủi ro và nêu rõ sai số hoặc giới hạn của phương pháp kiểm thử.
- + Áp dụng bản vá, tắt SMBv1, cấu hình tường lửa hoặc giới hạn TCP 445 và đề xuất phân đoạn mạng; sau đó chạy lại cùng bộ kiểm thử.
- + Bàn giao sơ đồ lab, bảng địa chỉ IP, ma trận trước-sau phòng thủ, log và ảnh minh chứng có chú thích, báo cáo hoàn chỉnh và slide trình bày.

8. Môi trường thực hiện

- Nền tảng ảo hóa VMware Workstation hoặc Oracle VirtualBox.
- Máy kiểm thử Kali Linux có Nmap, Nmap Scripting Engine và Metasploit Framework.
- Máy Windows mục tiêu thuộc phạm vi ảnh hưởng của MS17-010; phải ghi nhận rõ phiên bản, bản dựng, kiến trúc và trạng thái bản vá.
- Mạng ảo Host-only hoặc Internal Network, dùng địa chỉ IP tĩnh; không kết nối máy Windows chưa vá vào mạng thật hoặc Internet.
- Snapshot máy ảo, Windows Event Viewer và thư mục lưu log/ảnh minh chứng phục vụ khôi phục và đối chiếu kết quả.

9. Thời gian thực hiện: 10 tuần (từ ngày 24/08/2026 đến ngày 18/10/2026)

10. Thang điểm

STT	Nội dung	CLO	Điểm
1	Phân tích đề tài	CLO1.1	
	• Xác định mục tiêu, phạm vi và giới hạn đạo đức		0.25
	• Khảo sát hiện trạng dịch vụ SMB		0.25
	• Đề xuất mô hình kiểm thử và giải pháp phòng thủ		0.25
2	Lập kế hoạch và phân công thực hiện công việc	CLO6	0.25
3	Nghiên cứu cơ sở lý thuyết và công cụ	CLO1.2	
			0.5
	• Mô tả SMB, MS17-010 và nguy cơ liên quan		0.25
	• Giới thiệu Nmap, NSE và Metasploit Framework		
4	• Mô tả công nghệ, công cụ và mô hình phù hợp	CLO2.1	0.25
			0.5
	• Vẽ sơ đồ mô hình lab và luồng kiểm thử		
5	Mô tả vai trò, chức năng và quan hệ của các thành phần trong mô hình lab	CLO2.2	0.5
6	Triển khai mô hình:	CLO3	
	• Xây dựng kịch bản và tiêu chí kiểm thử		0.5
	• Lựa chọn công cụ và môi trường thực nghiệm		0.5



TRƯỜNG ĐẠI HỌC CÔNG THƯƠNG TP.HCM
KHOA CÔNG NGHỆ THÔNG TIN

STT	Nội dung	CLO	Điểm
	• Mô tả cấu hình Kali Linux, Windows và mạng ảo • Triển khai hạ tầng ảo và cơ chế cô lập mạng • Khảo sát dịch vụ SMB bằng Nmap • Xác minh trạng thái MS17-010 • Thực nghiệm kiểm thử có kiểm soát • Áp dụng biện pháp phòng thủ • Kiểm thử lại và thu thập minh chứng		0.5 0.5 0.5 0.5 0.5 0.5 0.5
7	Đánh giá kết quả trước-sau phòng thủ, mức độ rủi ro và rủi ro còn lại	CLO4	0.5
8	Nội dung kiến thức trình bày trong quyền báo cáo.	CLO5.1	0.5
9	Hình thức, định dạng quyền báo cáo.	CLO5.1	0.5
10	Thái độ, tác phong làm việc	CLO6	0.5
11	Phong cách báo cáo, Slide.	CLO5.2	0.5
Tổng cộng			10.0

11. Thời gian và các công việc trong tuần:

STT	Tuần	Nội dung công việc
1	1	• Chốt mục tiêu, phạm vi, nguyên tắc an toàn và tiêu chí nghiệm thu. • Lập kế hoạch, phân công công việc và thống nhất cách lưu bằng chứng.
2	2	• Nghiên cứu kiến trúc SMB, các phiên bản giao thức, cổng 139/445 và cơ chế xác thực. • Lập sơ đồ luồng giao tiếp SMB và bảng thuật ngữ dùng trong báo cáo.
3	3	• Phân tích MS17-010, nhóm CVE liên quan, hệ điều hành bị ảnh hưởng và điều kiện khai thác. • Nghiên cứu Nmap, NSE và Metasploit Framework; xác định giới hạn sử dụng trong lab.
4	4	• Thiết kế mô hình mạng cô lập, bảng địa chỉ IP và cấu hình máy ảo. • Cài đặt Kali Linux, Windows mục tiêu; tạo snapshot và kiểm tra khả năng phục hồi.
5	5	• Ghi nhận phiên bản/bản dựng Windows, trạng thái bản vá và cấu hình SMB ban đầu. • Thực nghiệm phát hiện máy, quét cổng 139/445 và nhận diện dịch vụ SMB bằng Nmap.



TRƯỜNG ĐẠI HỌC CÔNG THƯƠNG TP.HCM
KHOA CÔNG NGHỆ THÔNG TIN

STT	Tuần	Nội dung công việc
6	6	- Xác định phiên bản SMB và kiểm tra MS17-010 bằng phương pháp phát hiện đã chọn. - Đối chiếu kết quả giữa Nmap/NSE, cấu hình Windows và trạng thái bản vá.
7	7	- Thực hiện kịch bản kiểm thử có kiểm soát theo phạm vi đã phê duyệt. - Thu thập log, ảnh minh chứng; phân tích điều kiện thành công, thất bại và tác động.
8	8	- Áp dụng bản vá, vô hiệu hóa SMBv1, giới hạn TCP 445 và đề xuất phân đoạn mạng. - Kiểm thử lại bằng cùng tiêu chí; lập ma trận so sánh trước-sau phòng thủ.
9	9	- Đánh giá rủi ro, rủi ro còn lại, ảnh hưởng tương thích và giới hạn của mô hình. - Hoàn thiện các chương lý thuyết, mô hình, thực nghiệm, kết quả và khuyến nghị.
10	10	- Rà soát số liệu, chú thích ảnh, trích dẫn và định dạng báo cáo. - Hoàn thiện slide, tập bảo vệ, nộp báo cáo và sản phẩm minh chứng.

12. Tài liệu tham khảo

[1]. Microsoft, “*Microsoft Security Bulletin MS17-010 – Critical*”, 2017,

<https://learn.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010>, truy cập tháng 8/2026.

[2]. Microsoft Learn, “*Detect, enable, and disable SMBv1, SMBv2, and SMBv3 in Windows*”,

2025, <https://learn.microsoft.com/en-us/windows-server/storage/file-server/troubleshoot/detect-enable-and-disable-smbv1-v2-v3>, truy cập tháng 8/2026.

[3]. Gordon Lyon, “*Nmap Network Scanning: The Official Nmap Project Guide to Network*

Discovery and Security Scanning”, Insecure.Com LLC, 2009, <https://nmap.org/book/>, truy cập tháng 8/2026.

[4]. Nmap Project, “*smb-vuln-ms17-010 NSE script*”, 2017, <https://nmap.org/nsedoc/scripts/smb-vuln-ms17-010.html>, truy cập tháng 8/2026.

[5]. Rapid7, “*Metasploit Framework Documentation – Running modules*”, không ghi năm,

<https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html>, truy cập tháng 8/2026.

[6]. National Institute of Standards and Technology, “*CVE-2017-0144 Detail*”, National

Vulnerability Database, 2017, <https://nvd.nist.gov/vuln/detail/CVE-2017-0144>, truy cập tháng 8/2026.



TRƯỜNG ĐẠI HỌC CÔNG THƯƠNG TP.HCM
KHOA CÔNG NGHỆ THÔNG TIN

- [7]. Andrew S. Tanenbaum, Nick Feamster và David J. Wetherall, “*Computer Networks*”, ấn bản thứ 6, Pearson, 2021, <https://www.pearson.com/en-us/subject-catalog/p/computer-networks/P200000003188/9780137523214>, truy cập tháng 8/2026.
- [8]. Pavel Yosifovich, Mark E. Russinovich, Alex Ionescu và David A. Solomon, “*Windows Internals, Part 1: System Architecture, Processes, Threads, Memory Management, and More*”, ấn bản thứ 7, Microsoft Press, 2017, <https://www.microsoftpressstore.com/store/windows-internals-part-1-system-architecture-processes-9780133986464>, truy cập tháng 8/2026.
- [9]. Andrea Allievi, Alex Ionescu, Mark E. Russinovich và David A. Solomon, “*Windows Internals, Part 2*”, ấn bản thứ 7, Microsoft Press, 2021, <https://www.microsoftpressstore.com/store/windows-internals-part-2-9780135462409>, truy cập tháng 8/2026.
- [10]. Georgia Weidman, “*Penetration Testing: A Hands-On Introduction to Hacking*”, No Starch Press, 2014, <https://nostarch.com/pentesting>, truy cập tháng 8/2026.
- [11]. Chris McNab, “*Network Security Assessment*”, ấn bản thứ 3, O’Reilly Media, 2016, <https://www.oreilly.com/library/view/network-security-assessment/9781491911044/>, truy cập tháng 8/2026.
- [12]. David Kennedy, Mati Aharoni, Devon Kearns, Jim O’Gorman và Daniel Graham, “*Metasploit*”, ấn bản thứ 2, No Starch Press, 2024, <https://nostarch.com/metasploit-2nd-edition>, truy cập tháng 8/2026.



TRƯỜNG ĐẠI HỌC CÔNG THƯƠNG TP.HCM
KHOA CÔNG NGHỆ THÔNG TIN

13. Một số yêu cầu khác

1. Số lượng sinh viên tối đa thực hiện đề tài: 3 sinh viên.
2. Có kiến thức cơ bản về mạng máy tính, hệ điều hành Windows/Linux và quản trị máy ảo.
3. Gặp giảng viên hướng dẫn ít nhất 1 lần/tuần và thực hiện đúng phần việc được giao. Trước mỗi buổi báo cáo, nhóm phải tích hợp kết quả, log và ảnh minh chứng vào một tài liệu chung.
4. Mọi thao tác quét, xác minh và khai thác chỉ được thực hiện trên máy ảo do nhóm sở hữu hoặc được cho phép rõ ràng; không đưa máy Windows chưa vá ra mạng thật và không phát tán mã khai thác.

Tp.HCM, ngày ... tháng ... năm 2026

Trưởng bộ môn
(ký và ghi rõ họ tên)

Giảng viên hướng dẫn
(ký và ghi rõ họ tên)